Note de sécurité

Messagerie souveraine de l'administration publique : Sprint technique pré-hackathon 2026 (MTDPCE/DGTD)

Équipe : Argus - École Polytechnique de Ouagadougou - Version du 3 novembre 2026

1. Architecture et périmètre

Messagerie instantanée Matrix : serveur **Synapse** avec base **PostgreSQL**, client web **Element**, identité et second facteur **Keycloak** (relié à Synapse par OIDC), reverse proxy **Caddy**. Le tout est déployé par Docker Compose sur une infrastructure locale ; en fonctionnement, aucun service tiers n'est nécessaire (les images sont téléchargées à l'installation). Niveau d'engagement : étendre et adapter. **Aucune cryptographie n'a été développée par l'équipe.**

2. Menaces et mesures de protection

Menace	Mesure de protection	Vérification
Serveur curieux ou compromis	Chiffrement de bout en bout (Olm/Megolm) activé par défaut dans toutes les salles ; clés privées conservées dans le navigateur des agents ; fichiers chiffrés avant envoi.	**Testé** : après échange d'un message et d'un fichier, 0 message en clair en base, 2 évènements chiffrés, marqueurs introuvables dans la base et dans le dépôt de médias.
Intrus non enrôlé	Inscription publique fermée ; comptes créés par un administrateur dans Keycloak ; aucune auto-inscription ; pas de fédération.	**Testé** : inscription refusée (HTTP 403), connexion par mot de passe refusée.
Mot de passe volé ou deviné	Second facteur TOTP obligatoire ; mot de passe et code redemandés à chaque connexion ; connexion par mot de passe Matrix désactivée (pas de contournement) ; politique de 12 caractères ; blocage temporaire Keycloak après 5 échecs.	**Testé** : le serveur ne propose que la connexion Keycloak ; reconnexion : mot de passe puis code redemandés. Politique de mot de passe et blocage : configurés, non testés.
Départ d'un agent, appareil perdu	Révocation en une commande : identité Keycloak désactivée et sessions fermées, compte Matrix désactivé, jetons et appareils supprimés, retrait des salles (ce qui conduit les clients à renouveler les clés du groupe).	**Testé** : 19 vérifications automatisées sur 19 ; en démonstration, l'agent perd sa session et Keycloak refuse la reconnexion. Renouvellement des clés par les clients : non vérifié directement.
Écoute du réseau	TLS pour toutes les connexions des navigateurs (Caddy, autorité interne, HSTS). Échanges Synapse-Keycloak en HTTP sur le réseau interne Docker.	Accès HTTPS constaté ; capture réseau **non réalisée** à ce jour.
Fuite par notifications ou aperçus	Pas de notifications push (services tiers) ; contenu exclu des notifications ; aperçus d'URL désactivés.	Configuré, non testé en conditions réelles.
Exposition de l'administration	API d'administration de Synapse et de Keycloak liées à 127.0.0.1 ; Caddy n'expose que l'API Matrix, Keycloak (/auth) et Element.	Configuration relue (voir limite 5 pour la console Keycloak).
Abus et saturation	Limites de débit (messages, connexions) et taille des fichiers limitée à 50 Mo.	Configuré, non testé en mode OIDC.

3. Mécanismes cryptographiques et gestion des clés

- **Protocole** : Matrix, avec Olm (sessions entre appareils) et Megolm (sessions de groupe), via les bibliothèques officielles d'Element. Les primitives (Curve25519, Ed25519, AES-256, HMAC-SHA-256) sont celles de la spécification Matrix.
- **Génération et stockage** : les clés d'identité et de session sont générées dans le navigateur de chaque appareil et conservées dans son stockage local. Le serveur ne les reçoit jamais.
- **Fichiers** : chiffrés dans le navigateur avant envoi ; le serveur ne stocke que des données illisibles.
- **Sauvegarde** : l'agent crée une clé de récupération ; le serveur ne conserve qu'une sauvegarde chiffrée des clés. Sans cette clé, l'historique n'est pas récupérable sur un nouvel appareil.
- **Renouvellement et révocation** : les sessions Megolm sont renouvelées selon les paramètres de Matrix et lors d'un changement de membres du groupe. Un appareil supprimé ou un agent retiré d'un groupe ne reçoit plus les nouvelles clés.
- **Authentification** : mots de passe conservés sous forme hachée par Keycloak ; code TOTP à 6 chiffres (RFC 6238) ; jetons de session Matrix invalidés à la révocation.

4. Métadonnées visibles par le serveur

Le serveur voit toujours : l'identité des comptes, l'appartenance aux salles (donc qui échange avec qui), l'horodatage et la taille de chaque message ou fichier, le type d'évènement, les noms et identifiants d'appareils, l'adresse IP et l'agent utilisateur des connexions, les profils (nom, avatar) et les accusés de lecture.

Mesures de réduction : pas de fédération ; présence désactivée ; aperçus d'URL désactivés ; journaux d'accès coupés ; conservation des adresses IP limitée à 7 jours ; profils réservés aux utilisateurs authentifiés. Ces mesures réduisent l'exposition, elles ne la suppriment pas.

5. Limites connues

- **Révocation** : elle coupe l'accès au serveur, mais n'efface pas ce qu'un appareil a déjà déchiffré. Un verrouillage applicatif et un effacement local seraient nécessaires.
- **Serveur compromis** : il pourrait tenter d'ajouter un appareil malveillant à un compte ; la vérification croisée des appareils (cross-signing) n'est pas imposée.
- **Second facteur** : le TOTP est imposé par une action requise de Keycloak, qu'un administrateur de Keycloak pourrait retirer à un compte. Keycloak est aussi un point de dépendance : arrêté, il empêche toute connexion. Un mode de repli par mot de passe existe, sans second facteur.
- **Échanges internes** : Synapse et Keycloak communiquent en HTTP sur le réseau Docker de la machine ; le certificat TLS provient d'une autorité interne locale, à remplacer par celle de l'État.
- **Keycloak de démonstration** : base H2 locale, mot de passe administrateur de démonstration, console accessible sous /auth/admin. À durcir en production (PostgreSQL, accès restreint, mot de passe fort).
- **Chaîne d'approvisionnement et sauvegardes** : images Docker non épinglées sur des versions précises ; les sauvegardes contiennent les métadonnées et doivent être chiffrées.
- **Comptes de démonstration** : fictifs, avec mots de passe publiés dans le dépôt ; à supprimer hors démonstration.
- **Non réalisé** : capture réseau, test du renouvellement des clés de groupe, audit de sécurité externe, notifications push mobiles.